PETUNJUK OPERASIONAL BANK MANDIRI

PO-DIR/IT/042/2024: TATA KELOLA KETAHANAN SIBER, MANAJEMEN DATA, DAN OPERASIONAL PERBANKAN DIGITAL

BAB I KETENTUAN UMUM

Pasal 1

(1) Petunjuk Operasional ini mengatur standar teknis tata kelola ketahanan siber, manajemen perlindungan data nasabah, dan kelangsungan operasional layanan perbankan digital di lingkungan PT Bank Mandiri (Persero) Tbk.

BAB II PENGAMANAN DATA DAN PRIVASI NASABAH

Pasal 4

(1) Setiap data rahasia perbankan dan data sensitif nasabah wajib dienkripsi pada saat transmisi menggunakan protokol TLS 1.3 dan pada saat diam (at-rest) menggunakan algoritma standar Advanced Encryption Standard 256-bit (AES-256).

Pasal 7

(1) Apabila terjadi insiden kegagalan pelindungan atau dugaan kebocoran data pribadi nasabah, Unit Kerja Pengelola Data wajib menyampaikan pemberitahuan tertulis kepada nasabah paling lambat 14 (empat belas) hari kerja terhitung sejak insiden teridentifikasi.

BAB III KELANGSUNGAN OPERASIONAL DAN BCP

Pasal 12

(1) Recovery Time Objective (RTO) untuk pemulihan sistem aplikasi kritikal perbankan pada Pusat Pemulihan Bencana (Disaster Recovery Center/DRC) ditetapkan paling lama 4 (empat) jam sejak status darurat atau bencana dinyatakan aktif oleh Komite Manajemen Krisis.

BAB IV PENEMPATAN PUSAT DATA DAN CLOUD COMPUTING

Pasal 18

(1) Bank dapat menempatkan pusat data operasional dan seluruh cadangan log transaksi finansial nasabah pada penyedia layanan komputasi awan (cloud) pihak ketiga yang lokasi server fisiknya berada di luar wilayah yurisdiksi Republik Indonesia tanpa persetujuan khusus regulator.

BAB V PEMANTAUAN DAN OPERASI KEAMANAN SIBER

Pasal 22

(1) Bank wajib mengoperasikan Security Operations Center (SOC) selama 24 (dua puluh empat) jam sehari dan 7 (tujuh) hari seminggu secara berkesinambungan guna melakukan pemantauan proaktif, deteksi dini, dan penanganan anomali keamanan siber.

BAB VI PENGUJIAN KEAMANAN SISTEM ELEKTRONIK

Pasal 26

(1) Pengujian keamanan siber melalui vulnerability assessment dan penetration testing (pentest) pada seluruh infrastruktur sistem elektronik bank wajib dilakukan oleh pihak independen bersertifikasi minimal 1 (satu) kali dalam 1 (satu) tahun.